M T W T F S S
Page No.
Date 12/10/26
YOUVA

Case Study:

Security the university Examination System

A university uses an Operating System based examination Managment System to store Student records, examination marks, faculty details and Question papers. The System has three main user groups: Students Should be able to view only their own marks and download permitted learning materials. Faculty members need to view Student records and enter or ~~need to view Student records~~ modify marks. Administrat -ors manage user accounts, permissions and System Configuration.

The university has assigned permissions through roles, but an audit review identifies the following events:

- At 10:00, the account Student 07 has three failed login attempts.
- At 10:03, Student 07 ~~has three failed~~ successfully logs in.
- At 10:04, Student 07 attempts to open exam marks.xlsx, which contains marks for an entire class.
- At 10:05, the System records an attempted modifications of modifications of to Exammarks.xlsx by Student 07.
- At 10:15, Faculty 82 modify marks is Exammarks.xlsx and saves the file successfully.
- At 10:20, an admistrator discovers that a former faculty members account is still active.

- The audit log is Stored on the same server and users with broad permissions may be able to modify or delete it.

The university wants to protect confidentiality, integrity and availability, prevent the unauthorized access, Maintain accountability and investigate suspicious activity. You are asked to recommend appropriate operating access control security - administration and auditing.

Q/A:-

Q1) Identify the main Security Problems in the Case Study. (at least 4 risks or Weaknesses.)

→ 1) Broken Access control on Sensitive Files
2) Failure in Account offboardings (zombie Accounts).
3) Insecure and Tamper prone Audit logs
4) Lack of Brute-Force or login Protection

Q2) Explain the differentiate between authentication and authorization using Student 07 as an Example.

→ Authentication means verifying the identity of a user. In this case, the system records three failed login attempts by Student 07 at 10:00, followed by a successful login at 10:03.

Authorization means checking what actions a user is permitted to perform. Student 07 may access permitted learning materials and their own marks, but should not be allowed to modify.

Thus, authentication verifies the user's identity, while authorization checks their access permissions.

Q3) Recommend an access control policy for students, Faculty and Administrators. Justify your choice.

→ The university should use Role-Based Access Control (RBAC), where permissions are assigned according to each user's role.

- Students: view their own marks and download learning materials to protect privacy.
- Faculty: view student records and update marks for their classes to perform academic duties.
- Administrators: manage accounts, permissions and system settings to maintain security.

RBAC ensures that each user can access only what their role allows.

Q4) Prepare a suitable Access Control List (ACL) for Exam Marks .XSLX.

→

User	Read	Write/modify	Delete
Students	NO	NO	NO
Faculty	Yes	Yes	NO
Administrators	Yes	Yes	Yes

Q5) Explain how the principal of least privilage should be applied to this System.

→ It means giving users only the permissions needed to perform their work.

1) Student - Can view only their own marks and download permitted materials.
2) Faculty - Can view Student records and modify marks only for their assigned classes.
3) Administrators - Can manage accounts, permissions and System settings only as required.

Q6) Interpret the audit events from 10:00 to 10:05. What should the security team do next?

→
- Review login and audit logs
- Check wheather access was denied
- Temporarily block the account if suspicious activity continues.

- Preserve evidence and ~~to~~ investigate the incident.
- Strengthen access controls and monitor future activity.

Q7) Identify at least five events that should be recorded in the audit logs.

→ 1) Failed login attempts by Student 07 at 10:00
2) Successful login by Student 07 at 10:03
3) unauthorized file access attempt to ExamMarks.xlsx at 10:04
4) Attempted modification of ExamMarks.xlsx by Student 07 at 10:05
5) Successful modification of marks by Faculty 02 at 10:15

Q8) Explain why the audit logs must be protected and recommend two ways to protect them.

→ Audit logs must be protected to prevent ~~to~~ unauthorized ~~the~~ modification or deletion and to ensure reliable evidence for investigating security incidents.

1) Store logs on a separate, secure server with restricted access.
2) Use write-protected or tamper-proof logs so users cannot change or delete them.

Q9) What action should be taken regarding the former faculty member's active account? Explain.

→ • Disable the account immediately to prevent unauthorized access.
• Remove all permissions and access rights linked to the former faculty member.
• Update account records and audit logs to maintain accountability and prevent future misuse.

Regular account management ensures that only current authorized staff can access the university system.

Q10) Suggest a pratical incident-response and corrective-action plan for the University.

→ 1) Investigate: Review the audit logs, verify Student 07's activities, and check wheather any marks were changed without authorization.

2) Review access: Disable the former ~~fast~~ faculty member's account and examine the permissions of students, faculty, and administrators.

3) Improve Security: Apply RBAC and the Principal of least privilege enforce strong passwords and enable multi-factor authentication where possible.

4) monitor regularly: Protect audit logs, review suspicious activities, conduct periodic access reviews, and verify that corrective

measures are effective.